

Beanstalk Audit Summary

Prepared by Cyfrin

Version 1.0

Lead Auditors

Giovanni Di Siena

Carlos Amarante

Assisting Auditors

Alex Roan

September 12, 2023

Contents

1 About Cyfrin **2**

2 About This Document **2**

3 Disclaimer **2**

4 Copyright and License **2**

5 Audit Overview **3**

6 Audit Scope **3**

7 Risk Classification **4**

8 Protocol Summary **4**

8.1 Overview 4

8.2 Key concepts 4

8.3 Sources 5

9 Attestation **5**

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Beanstalk Farms on Beanstalk. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number of findings by severity. It closes with Cyfrin's attestation of the review's scope.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 1.0 dated September 12, 2023, was delivered to Beanstalk Farms, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Beanstalk Farms or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 36 days, the Cyfrin team conducted an audit on the Beanstalk code provided by Beanstalk Farms. The findings consist of 2 High, 4 Medium & 11 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	Beanstalk
Repository	Beanstalk
Commit	c7a20e56a0a6...
Audit Timeline	Jul 24th - Sep 11th, 2023
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	–	–
High Risk	2	–	–
Medium Risk	4	–	–
Low Risk	11	–	–
Informational	35	–	–
Gas Optimizations	11	–	–
Total	63	–	–

This version of the report was issued before any fixes were reviewed: all findings were open.

6 Audit Scope

Cyfrin conducted an audit of Beanstalk based on the code present in the repository at commit c7a20e5.

Contracts present in the `protocol/contracts/*` directories were included in the audit scope, excluding:

```
protocol/contracts/mocks/*
protocol/contracts/ecosystem/root/Root.sol
protocol/contracts/beanstalk/AppStorageOld.sol
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

8.1 Overview

Beanstalk is a permissionless algorithmic stablecoin protocol built on Ethereum. The protocol uses a dynamic peg maintenance mechanism to have the price of 1 BEAN (the Beanstalk stablecoin) continuously cross its peg value of 1 USD without collateral requirements.

The Beanstalk ecosystem, known as the Farm, consists of five primary components:

1. The Sun: decentralized timekeeping and execution facility.
2. The Silo: decentralized governance facility (Beanstalk DAO). Offers passive yield opportunities to owners of Beans and other whitelisted assets who participate in governance and passively contribute to stability and liquidity.
3. The Field: decentralized credit facility. Offers yield opportunities to creditors for participating in peg maintenance, removing Beans from circulation in exchange for Pods (which could be interpreted as bonds).
4. The Market: decentralized exchange to buy and sell Pods without fees.
5. The Depot: interface to interact with other Ethereum-native protocols via Beanstalk.

Another important component is the Barn, Beanstalk's recapitalization facility. Through the Barn Raise, depositors were issued "Unripe" assets placed on a redemption schedule, and 77M of a semi-fungible debt issuance token, "Fertilizer", was made available to be bought for 1 USDC each. When Fertilizer is sold, Beanstalk adds liquidity to the BEAN:3CRV pool at a ratio of 1:0.866616. Fertilizer is redeemable for 1 BEAN plus an interest rate defined by the "Humidity". The sum of both values is the "Sprout" associated with the Fertilizer issuance. Sprouts become redeemable for Beans on a pari passu basis when Beanstalk mints new Beans according to the peg maintenance mechanism. Additional details can be found in the official documentation linked below.

8.2 Key concepts

- **Seasons:** Beanstalk measures time in Seasons, which target a duration of 1 hour. Each Season starts when a call to function `gm` is performed. `gm` can be called once per Season; its cost in ETH is compensated in BEAN to whoever calls the function, as an incentive that increases up to a maximum value.
- **Stalk system:** a system meant to decentralize ownership over time and create Beanstalk-native financial incentives to align DAO voters' interests with the health of Beanstalk, leave assets deposited in the Silo and allocate liquidity in ways that benefit Beanstalk. Users receive Stalk by depositing whitelisted assets into the Silo, giving them the right to earn a share of Bean seigniorage and additional Grown Stalk, which acts as an anti-reflexive "sticking" incentive.
- **Mow:** the action of converting Grown Stalk into Stalk. Each time a Stalkholder performs some action on their Silo deposits, the corresponding Grown Stalk for that whitelisted asset is converted to Stalk.
- **Conversions:** if deposited assets are withdrawn from the Silo, the Stalk accrued from this deposit is lost, so a user who wants to exchange one whitelisted asset for another and then re-deposit would lose their Stalk. Conversions allow users to exchange whitelisted assets without losing their Grown Stalk. Conversions are usually allowed only under certain conditions which contribute to peg maintenance.

- **Soil:** the number of Beans the Beanstalk protocol is willing to take out of circulation in order to increase its value, helping to return the price of BEAN to peg. Beanstalk issues debt as Pods in exchange for Beans when sowing Soil.
- **Pods:** the primary debt asset of Beanstalk, which never expires, ordered in a list in the form of Plots.
- **Plots:** identified by the total historical Pods issued at the moment of their creation.
- **Sow:** the action of exchanging Beans for Pods through the Field. This can be interpreted as lending Beans to Beanstalk.
- **Temperature:** the interest paid for lending Beans to Beanstalk. This is used to calculate how many Pods should be issued for a given amount of Beans.
- **Humidity:** the interest rate paid for minting Fertilizer.
- **Rain:** an event that occurs when the BEAN price is above 1 USD at the beginning of a Season and the debt level is below 5%.
- **Flood/Season of Plenty:** a Flood (also known as Season of Plenty) occurs after a given number of consecutive Seasons of Rain. Given that the Bean price has been above its 1 USD peg, new Beans are minted and sold for 3CRV to facilitate a return to peg. The result of the operation is distributed proportionally to Stalkholders.

8.3 Sources

- Beanstalk GitBook
- Beanstalk Whitepaper
- Beanstalk Blog
- Publius Blog
- Guy Blog

9 Attestation

Cyfrin attests that it performed a security review of the Beanstalk code provided by Beanstalk Farms.

The repositories, commits, review period and findings are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2023-09-12-cyfrin-beanstalk.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Beanstalk Farms has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=227ae0515e4b114f7b37ac31dd32d8d3773ae43d0d4e0867e07f8c41377f56b0
F=2023-09-12-cyfrin-beanstalk-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.